

Plan de Respuesta a Incidente de Ransomware basado en NIST – TechCo

1 - Identificación

El primer paso ante cualquier incidente de ciberseguridad es conocer qué activos son críticos para la empresa y qué riesgos pueden presentarse. En el caso de TechCo, el ataque de ransomware afectó directamente a sistemas esenciales para su funcionamiento diario.

Entre los activos más importantes se encuentran el servidor de archivos corporativo, donde se almacena la documentación interna necesaria para el trabajo diario, y la base de datos de clientes, que contiene información personal y financiera sensible. También son activos críticos la infraestructura de copias de seguridad, la red interna de la empresa y las credenciales de los usuarios, especialmente aquellas con permisos elevados.

La principal amenaza identificada es el ransomware distribuido a través de correos electrónicos de phishing. Este tipo de ataque aprovecha errores humanos para acceder a la red y propagarse rápidamente. En este caso, la falta de segmentación de red, la ausencia de controles avanzados en el correo electrónico y la ubicación de los backups en la misma red facilitaron que el ataque tuviera un impacto elevado.

2 - Protección

La función de protección se centra en aplicar medidas preventivas que reduzcan la probabilidad de sufrir un ataque similar.

A nivel técnico, TechCo debería haber contado con una red correctamente segmentada, separando los equipos de usuario, los servidores críticos y los sistemas de backup. Además, las copias de seguridad deberían haberse almacenado de forma segura, siguiendo la regla 3-2-1 (3 copias de los datos, en 2 soportes diferentes y 1 copia fuera del sistema principal, preferiblemente offline o inmutable). La implementación de soluciones EDR o XDR en los equipos habría permitido detectar comportamientos sospechosos antes de que el ransomware se propagara.

El correo electrónico es uno de los principales vectores de ataque, por lo que resulta clave disponer de filtros antiphishing y sistemas de análisis de adjuntos. Todo esto debe complementarse con el principio de mínimo privilegio, asegurando que cada usuario solo tenga los permisos estrictamente necesarios.

Desde el punto de vista organizativo, es fundamental contar con políticas de seguridad claras, un plan de respuesta a incidentes documentado y formación periódica para los

empleados. La concienciación del personal es una de las medidas más efectivas para prevenir ataques de este tipo.

3 - Detección

Detectar un ataque en sus primeras fases puede marcar la diferencia entre un incidente controlado y una crisis grave. En el caso de TechCo, la falta de monitorización provocó que el ransomware no se detectara hasta que ya había cifrado gran parte de los sistemas.

Para evitar esta situación, la empresa debería haber implementado sistemas de monitorización continua, como un SIEM que correlacione eventos de servidores, red y endpoints. Las soluciones EDR o XDR permiten detectar comportamientos típicos del ransomware, como el cifrado masivo de archivos, mientras que los sistemas IDS o IPS ayudan a identificar tráfico sospechoso en la red.

Además, es importante contar con un protocolo de alertas bien definido, que indique qué eventos son críticos y cómo deben escalar al equipo de seguridad para una actuación rápida.

4 - Respuesta

Una vez detectado el incidente, la rapidez y el orden en la respuesta son claves para minimizar los daños.

Las primeras acciones deben centrarse en aislar los sistemas afectados, desconectándolos de la red para evitar la propagación del malware. A continuación, deben bloquearse las credenciales que puedan estar comprometidas y analizar el alcance real del ataque.

El plan de respuesta debe definir claramente los roles y responsabilidades. El equipo de respuesta a incidentes se encarga de coordinar las acciones técnicas, el departamento de IT ejecuta las tareas de contención y recuperación, la dirección toma decisiones estratégicas y el área legal evalúa las posibles obligaciones legales y de notificación. La comunicación, tanto interna como externa, debe ser clara y controlada para evitar el pánico y proteger la reputación de la empresa.

En general, no se recomienda el pago del rescate, ya que no garantiza la recuperación de los datos y fomenta este tipo de delitos.

5 - Recuperación

La fase de recuperación tiene como objetivo volver a la normalidad de forma segura y controlada.

Los sistemas afectados deben limpiarse por completo y reinstalarse desde fuentes confiables. La restauración de los datos solo debe realizarse a partir de copias de seguridad que no hayan sido comprometidas. Durante este proceso, es importante activar un plan de continuidad de negocio para garantizar que los servicios más críticos sigan funcionando.

Una vez recuperados los sistemas, se debe comprobar la integridad de los datos y mantener una vigilancia reforzada durante un periodo de tiempo para detectar posibles restos del ataque.

6 - Mejora continua

Después de gestionar el incidente, TechCo debe analizar lo ocurrido para aprender de la experiencia. Este análisis post-incidente permite identificar qué falló, qué funcionó correctamente y qué aspectos deben mejorarse.

Las lecciones aprendidas deben utilizarse para actualizar el plan de respuesta, reforzar los controles de seguridad y mejorar la formación del personal. También es recomendable realizar simulacros periódicos y auditorías de seguridad para comprobar que las medidas siguen siendo efectivas.